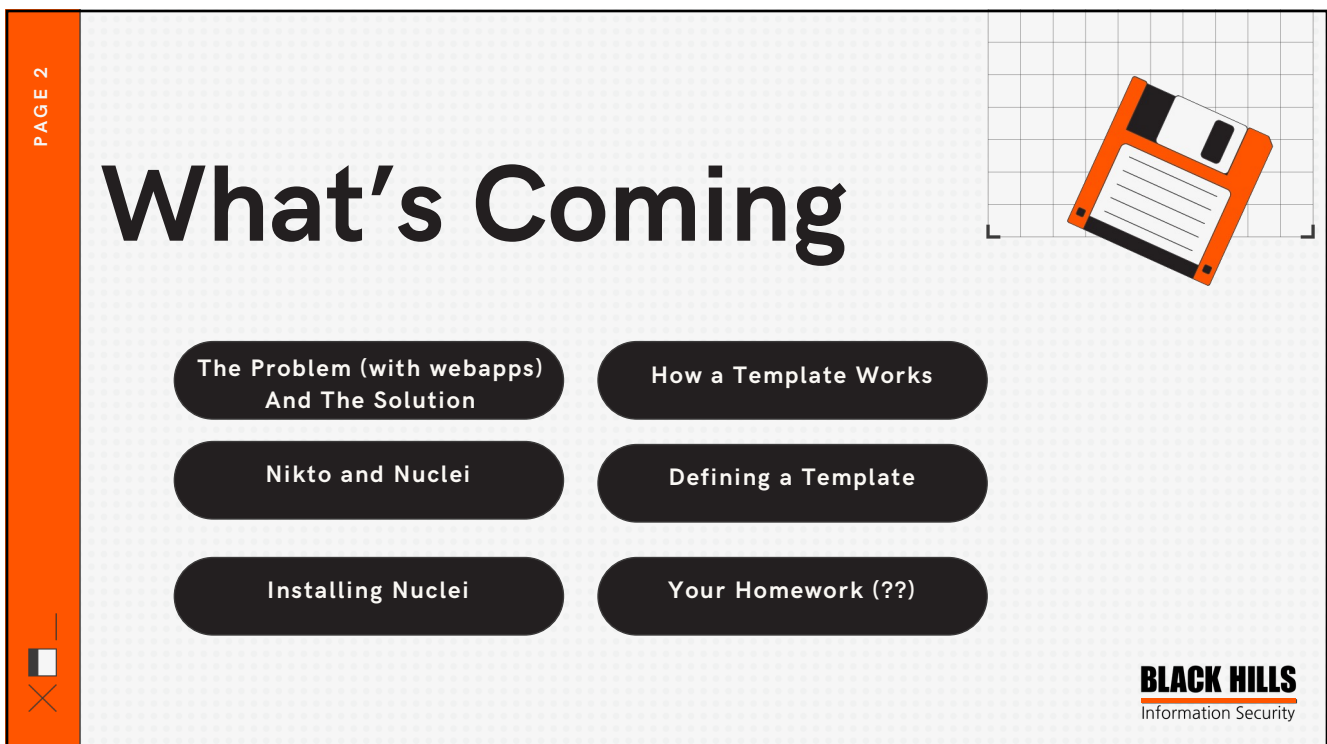




1



2

The Problem

Every webapp is different.
That's what makes them fun to test!
That's also what makes automated testing difficult.
Webapp vulnerability scanners are so tempting...
...and so un-automate-able.

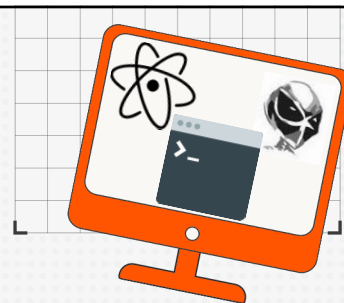


BLACK HILLS
Information Security

3

The Solution

Automate *What You Can*.
Do The Rest *By Hand* (hire it out, even)
Use *Existing Automation*.
And *Make Your Own As You Go*.



BLACK HILLS
Information Security

4

Nuclei is like Nikto...

<https://github.com/sullo/nikto>

If you know Nikto, then you know a lot about Nuclei
(it's OK if you don't - I'm about to explain):

- Both are scanners that look for misconfigurations^[1] on web servers^[2]
- Both are based on templates
 - Send a request like *this*, look for *that* in the response
- Both are easily extended
- Both allow running a subset of tests



5

Compare

☒ The Same

- ☐ Config by text file
- ☐ Define the request
- ☐ Identify key response bits
- ☐ Words for reporting a match
- ☐ Run many tests in one go, OR
- ☐ Run selected tests only

☒ The Different

- ☐ Nikto: 20+ years proven value
- ☐ Nuclei: 4+ years rapid growth
- ☐ Nikto: Perl, Nuclei: Golang
- ☐ Nikto: Simple matching
- ☐ Nuclei: Complex* matching
- ☐ Nikto: One rule, one request
- ☐ Nuclei: One rule, many requests
- ☐ Nuclei: Not just HTTP

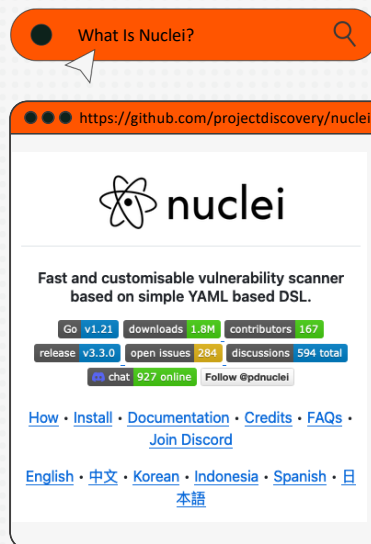


6

Nuclei Is...

"Nuclei is used to send requests across targets based on a template, leading to zero false positives and providing fast scanning on a large number of hosts. Nuclei offers scanning for a variety of protocols, including TCP, DNS, HTTP, SSL, File, Whois, Websocket, Headless, Code etc. With powerful and flexible templating, Nuclei can be used to model all kinds of security checks.

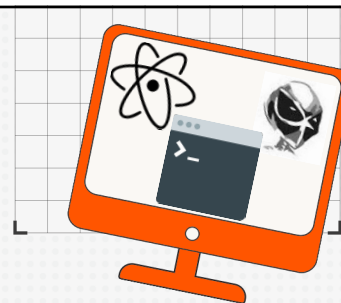
We have a dedicated repository that houses various type of vulnerability templates contributed by more than 300 security researchers and engineers."



BLACK HILLS
Information Security

But First, Nikto

<https://github.com/sullo/nikto>



BLACK HILLS
Information Security

Here's a JWKS File

JWKS: JSON Web Key Set
Public keys to verify a JWT signature.
Must have a "keys" array.



```
{
  "keys": [
    {
      "kty": "Ec",
      "crv": "P-256",
      "x": "MKBCtNIcKUSDii11ySs3526iDZ8AiTo7T",
      "y": "4EtL6SRW2YiLUzN5vfVvHuhp7x8PxltmW",
      "use": "enc",
      "kid": "1"
    },
    {
      "kty": "RSA",
      "n": "0vx7agoebGcQSuuPiLjXZptN9nndzQmbX",
      "e": "AQAB",
      "alg": "RS256",
      "kid": "2011-04-29"
    }
  ]
}
```

<https://datatracker.ietf.org/doc/html/rfc7517#appendix-A>

BLACK HILLS
Information Security

Find a JWKS File (Nikto Template)

 nikto/program/databases/db_tests:6988

ID, Refs, Tuning, **URI**, HTTP Method, **Match 1**, Match 1 Or, **Match 1 And**, Fail 1, Fail 2, Summary, HTTP Data, Headers
"007327", "RFC-5785", "3", "**/.well-known/jwks**", "GET", **"keys"**, "", **"kty"**, "", "", "JWKS file found", "", ""

That is...

Request the **/.well-known/jwks** URI.

If the response contains **"keys"** and **"kty"**, then
report discovery of a JWKS file



BLACK HILLS
Information Security

Here's That File Again...

Match: "keys"
and match: "kty"

```
{
  "keys": [
    {
      "kty": "Ec",
      "crv": "P-256",
      "x": "MKBCtNIcKUSDii11ySs3526iDZ8AiTo7T",
      "y": "4EtL6SRW2YiLUzN5vfVvHuhp7x8PxltmW",
      "use": "enc",
      "kid": "1"
    },
    {
      "kty": "RSA",
      "n": "0vx7agoebGcQSuuPiLJXZptN9nndzQmbX",
      "e": "AQAB",
      "alg": "RS256",
      "kid": "2011-04-29"
    }
  ]
}
```

<https://datatracker.ietf.org/doc/html/rfc7517#appendix-A>

Report JWKS File (Nikto view)

running Nikto

```
student@ncsa:~/$ cat program/databases/udb_tests
"007327","RFC-5785","3","/.well-known/jwks","GET","keys","","kty","","","JWKS file found","",""
student@ncsa:~/$ nikto -h http://192.168.1.205 -Userdb all -no404 -Plugins "@@none;tests"
- Nikto v2.5.0

-----
+ Target IP:      192.168.1.205
+ Target Hostname: 192.168.1.205
+ Target Port:    80
+ Start Time:     2024-07-30 12:25:31 (GMT-4)
-----
+ Server: Apache/2.4.58 (Ubuntu)
+ /.well-known/jwks: JWKS file found. See: RFC-5785
+ 3 requests: 0 error(s) and 1 item(s) reported on remote host
+ End Time:       2024-07-30 12:25:31 (GMT-4) (0 seconds)
-----
+ 1 host(s) tested
```



Report JWKS File (Server Log)

☒ tailing the server log

```
192.168.1.248 - - [30/Jul/2024:12:27:14 -0400] "GET / HTTP/1.1" 200 10982 "-" "Mozilla/5.0..."
192.168.1.248 - - [30/Jul/2024:12:27:14 -0400] "GET / HTTP/1.1" 200 10981 "-" "Mozilla/5.0..."
192.168.1.248 - - [30/Jul/2024:12:27:14 -0400] "GET /.well-known/jwks HTTP/1.1" 200 1301 "-" "Mozilla/..."
```

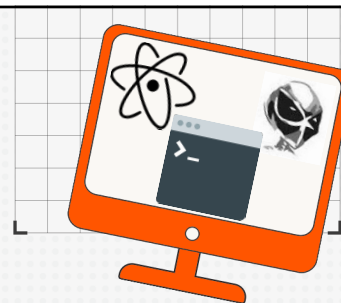
Those first two requests are confirming that the server is up.
Ignore those (also: be able to explain them).
The third is the check we're interested in.
HTTP 200, OK. Found it where we looked.



BLACK HILLS
Information Security

13

Now Do Nuclei



BLACK HILLS
Information Security

14

Report JWKS File (Nuclei Template)

⊗ nuclei-templates/http/exposures/tokens/jwk-json-leak.yaml

```
http:
  - method: GET
    path:
      - "{{BaseURL}}/.well-known/jwks.json"
      - "{{BaseURL}}/.well-known/jwks"
      - "{{BaseURL}}/.well-known/openid-configuration/jwks.json"
      - "{{BaseURL}}/.well-known/openid-configuration/jwks"
      - "{{BaseURL}}/jwks.json"
      - "{{BaseURL}}/jwks"
    . . .

stop-at-first-match: true
matchers-condition: and
matchers:
  - type: word
    part: body
    words:
      - "kid:"
  - type: word
    part: content_type
    words:
      - 'application/json'
  - type: status
    status:
      - 200
```



BLACK HILLS
Information Security

15

Here's that JWKS File Again

```
stop-at-first-match: true
matchers-condition: and
matchers:
  - type: word
    part: body
    words:
      - "kid:"
  - type: word
    part: content_type
    words:
      - 'application/json'
  - type: status
    status:
      - 200
```

```
{
  "keys": [
    {
      "kty": "EC",
      "crv": "P-256",
      "x": "MKBCtNIcKUSDi11ySs3526iDZ8AiTo7T",
      "y": "4EtL6SRW2YiLUrN5vfVvHuhp7x8PxltmW",
      "use": "enc",
      "kid": "1",
    },
    {
      "kty": "RSA",
      "n": "0vx7agoebGcQSuuPiLJXZptN9nndrQmbX",
      "e": "AQAB",
      "alg": "RS256",
      "kid": "2011-04-29"
    },
  ],
}
```

<https://datatracker.ietf.org/doc/html/rfc7517#appendix-A>

BLACK HILLS
Information Security

16

PAGE 17

Hold up

Nuclei looks for *something else*. Why?




, "keys", "", "kty",

Nikto

words:
- "kid":

Nuclei

JSON Web Key RFC

<https://www.rfc-editor.org/rfc/rfc7517>

IETF

4. JSON Web Key (JWK) Format

A JWK is a JSON object that represents a cryptographic key. The members of the object represent properties of the key, including its value. This JSON object MAY contain whitespace and/or line breaks before or after any JSON values or structural characters, in accordance with [Section 2 of RFC 7159 \[RFC7159\]](#). This document defines the key parameters that are not algorithm specific and, thus, common to many keys.

BLACK HILLS
Information Security

17

PAGE 18

RFC 7517 On What's Required...

✉ <https://www.rfc-editor.org/rfc/rfc7517.html#section-4>

4.1: The "kty" value is a case-sensitive string. This member **MUST be present** in a JWK. (Nikto looks for this) 

4.2: The "use" value is a case-sensitive string. Use of the "use" member is OPTIONAL.

4.3: Use of the "key_ops" member is OPTIONAL.

4.4: The "alg" value is a case-sensitive ASCII string. Use of this member is OPTIONAL.

4.5: The "kid" value is a case-sensitive string. Use of this member is **OPTIONAL**. (Nuclei looks for this) 

4.6-4.9: The "x5u" (X.509 URL) parameter [bb: and x5c and x5t and x5t#S256] are OPTIONAL.

5: A JWK Set is a JSON object that represents a set of JWKs.
The JSON object **MUST have a "keys"** member, with its value being an array of JWKs. (Nikto also looks for this)

✓ Advantage: Nikto

BLACK HILLS
Information Security

18

It's all about the fundamentals



BLACK HILLS
Information Security

19

Report JWKS File (Nuclei view)

Running Nuclei

```
student@ncsa:~$ nuclei -u http://192.168.1.205/ -t http/exposures/tokens/jwk-json-leak.yaml
```

```
[snip]
```

```
[INF] Current nuclei version: v3.3.0 (latest)
```

```
[INF] Current nuclei-templates version: v9.9.2 (latest)
```

```
[WRN] Scan results upload to cloud is disabled.
```

```
[INF] New templates added in latest release: 67
```

```
[INF] Templates loaded for current scan: 1
```

```
[INF] Executing 1 signed templates from projectdiscovery/nuclei-templates
```

```
[INF] Targets loaded for current scan: 1
```

```
[jwk-json-leak] [http] [low] http://192.168.1.205/.well-known/jwks
```



BLACK HILLS
Information Security

20

Report JWKS File (Server Log)

Running Nuclei

```
192.168.1.248 - - [30/Jul/2024:12:30:12 -0400] "GET /.well-known/jwks.json HTTP/1.1" 404 455 "-" "Mozilla/5.0..."
192.168.1.248 - - [30/Jul/2024:12:30:12 -0400] "GET /.well-known/jwks HTTP/1.1" 200 1265 "-" "Mozilla/5.0 ..."
```



This is everything our invocation asked for.
In the template, we had:

- 6 URIs to check
- "stop on first match" set to "true"
- We got a hit on the second one
- Efficient



BLACK HILLS
Information Security

21

Nuclei Use Cases

Individual Web Servers

- ☐ Scan with all public templates
- ☐ Trim out problematic ones
- ☐ Create your own
- ☐ Based on pentest results
- ☐ Run them on a schedule
- ☐ Run them in CI/CD
- ☐ Run them before next pentest

Collections of Servers

- ☐ Scan with all public templates
- ☐ Scan with Workflows for focus
- ☐ Scan by deployed technologies
- ☐ Scan all systems for \$latest_vuln
- ☐ Link w/ httpx & Katana discovery
- ☐ Project docs & vids are awesome



BLACK HILLS
Information Security

22

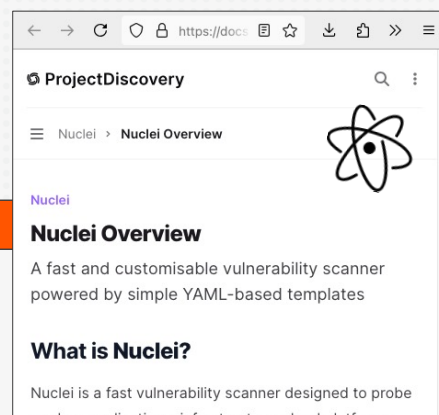
Nuclei Setup

```
Install Golang >= 1.21
$ go version # maybe you already have what you need? If not, then...
https://go.dev/doc/install

Install Nuclei
$ go install -v github.com/projectdiscovery/nuclei/v3/cmd/nuclei@latest

Autoconfigure Nuclei: run once with no arguments
$ nuclei

Read the docs
$ nuclei -h
or visit: https://github.com/projectdiscovery/nuclei?tab=readme-ov-file#usage
even better: https://docs.projectdiscovery.io/tools/nuclei/overview
```



How a Nuclei Template Works

What are Nuclei Templates?

Nuclei templates are the cornerstone of the Nuclei scanning engine. Nuclei templates enable precise and rapid scanning across various protocols like TCP, DNS, HTTP, and more. They are designed to send targeted requests based on specific vulnerability checks, ensuring low-to-zero false positives and efficient scanning over large networks.

A Nuclei template is a complete description of the issue in question.

Human-readable and machine-readable, in one text file.

ID for uniqueness

Info: name, author, severity, description, references, tags, metadata

Protocol in use (sticking with HTTP today)

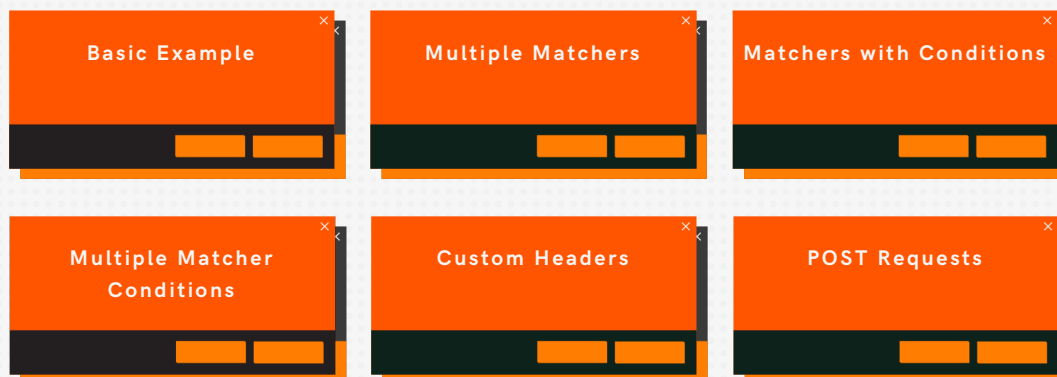
Request to Send (method, URI, body, etc)

Matchers: what to look for in the response

Examples



Visit <https://docs.projectdiscovery.io/templates/protocols/http/basic-http-examples>



BLACK HILLS
Information Security

25

Defining a Nuclei Template

```
id: finding-some-file

info:
  name: File Finder
  severity: info

http:
  - method: GET
    path:
      - "{{BaseURL}}/your/file/here"
    matchers-condition: and
    matchers:
      - type: word
        part: body
        words:
          - "<TITLE>Just The File I Wanted!</TITLE>"
          - "Other words that must be here, too"
```

BLACK HILLS
Information Security

26

Your Homework



Define a Nuclei Template for Apache's server-status

- Start with the template from a couple slides back
- Look at <http://cybertoes.com/server-status>
- Decide what's unique about that response
- Set up matchers to notice those things
- Run it
 - `nuclei -u http://cybertoes.com/ -t ./path/to/your-template-filename.yaml`
- Tweak and repeat
- Look at the public version when you want to:
 - `nuclei -td -t http/misconfiguration/apache/apache-server-status.yaml`



We're all friends, here, right?



Don't make me tap the sign

- This server isn't linked to anything.
- It has no data on it.
- There are no easter eggs.
- No reason to attack it, is what I'm saying.
- You are hereby authorized to:
 - use the `/server-status` resource to help write your Nuclei template.
 - use the `/.well-known/jwks` resource to repeat the commands shown earlier.
- I'll take it down in a few days at the latest.



`<script>alert(1)</script>`

"There is never enough time.

Thank you for yours."

-- Dan Geer (and BBKing)

REPORTING for PENTESTERS
w/ BB King
A 4-Hour Class

MODERN WEBAPP PENTESTING
w/ BB KING

<https://www.antisiphontraining.com/on-demand-courses/>

29